MONISH.S

192311132

CSE

ITA1409-ETHICAL HACKING

CO1-AT3

Ethical Hacking – Answers (1–10)

1. Should you exploit a critical vulnerability outside the authorized scope?

No, I should not exploit it without additional written permission because ethical hacking must follow authorization, scope, and responsible disclosure principles.

2. How should you handle SQL injection in a production database containing financial data?

I should avoid accessing real customer data, use safe proof-of-concept testing, and obtain explicit approval; safeguards should include backups, test data, a defined scope, and a rollback plan.

3. What should you do after accidentally causing a DoS outage?

I should immediately stop testing, notify the client, help restore the service, document the incident, and prevent recurrence through safer testing procedures.

4. What are the risks of testing without informing the IT department?

It may trigger incident response, cause disruption, and create confusion; I should obtain written authorization, define emergency contacts, and agree on a controlled testing plan.

5. How does a red-team exercise differ from a vulnerability assessment?

A red-team exercise simulates realistic attacks against a bank's physical and digital security, while a vulnerability assessment identifies and prioritizes weaknesses; both require authorization and clear rules of engagement.

6. What should you do if a vulnerability exposes other clients' data on a shared server?

I should stop testing, avoid accessing other clients' data, document minimal evidence, and report the issue because the other clients' systems are outside my authorization.

7. What are the risks of using automated exploitation tools without understanding them?

Such tools may damage systems, expose data, or cause outages; ethical hackers must understand their tools, validate results, and follow approved testing procedures.

8. Should you share a client's penetration-test findings with its competitor for money?

No, because doing so violates confidentiality and professional ethics and may result in legal consequences for unauthorized disclosure of client information.

9. How would you classify a 16-year-old who reports a school portal flaw without exploiting it?

The student can be considered a responsible security researcher or a potential white-hat hacker because they reported the flaw without exploiting it, although formal authorization is still important.

10. Is an employee who leaks internal documents after being denied a promotion a hacker?

The employee is an insider threat or malicious insider because they misuse legitimate access for revenge, potentially violating confidentiality policies and applicable laws.

Ethical Hacking – Answers (11–20)

11. Is publicly releasing an unpatched exploit ethical hacking?

Not necessarily; releasing an exploit before notifying the vendor can endanger users, making the researcher a potentially irresponsible or grey-hat actor.

12. How should a nation-state group attacking a hospital be classified?

It is a state-sponsored hacking group conducting a malicious cyberattack, potentially involving cyberterrorism or cyberwarfare depending on its purpose and circumstances.

13. Is scanning random IP addresses without permission grey-hat hacking?

It may be considered grey-hat activity because the intent may not be malicious, but unauthorized scanning can violate policies or laws depending on the circumstances.

14. Compare two researchers who discover the same zero-day vulnerability.

The researcher who reports it responsibly is acting as a white-hat researcher, while the person selling it on a dark-web marketplace may be a black-hat actor depending on their intent and activities.

15. Is secretly accessing a colleague's email account ethical hacking?

No, not without proper legal authority and authorization because management's request alone does not necessarily justify accessing another person's email.

16. How should an AI bot that scans IoT devices without consent be classified?

Its creator may be considered a grey-hat researcher if the intent is defensive, but unauthorized probing raises ethical and legal concerns; autonomous security research may require additional classifications.

17. What should you do if you discover unrelated criminal activity during a penetration test?

I should preserve relevant evidence securely, avoid investigating beyond scope, consult my supervisor or legal counsel, and follow contractual, confidentiality, and applicable reporting obligations.

18. What if excluded departments contain the greatest security risks?

I should respect the agreed scope, document my concerns, and recommend additional testing through proper authorization rather than testing excluded systems independently.

19. Is impersonating a grieving relative ethical during social engineering testing?

It may cause unnecessary psychological harm, so I should use a less distressing pretext that meets the testing objectives and follows agreed ethical safeguards.

20. Should you fully exploit a vulnerability that could crash hospital monitoring systems?

No, patient safety takes priority; I should stop short of dangerous exploitation, explain the risk, and seek approval for a safe alternative.

Ethical Hacking – Answers (21–30)

21. Is reusing anonymized penetration-test data in public case studies ethical?

Only with informed client consent, effective anonymization, confidentiality safeguards, and compliance with applicable contractual and legal requirements.

22. Is a fake layoff announcement appropriate for phishing awareness testing?

It may cause significant anxiety, so a less distressing scenario should be used with approved rules, safeguards, and appropriate employee support.

23. Can an ethical hacker keep client exploit code and credentials for personal use?

No, retaining client credentials or exploit materials without permission violates confidentiality, data-security obligations, and professional ethics.

24. What if a client's business model appears to be a scam?

I should distinguish technical findings from unverified suspicions, document relevant evidence, seek legal or compliance advice, and report through appropriate lawful channels when required.

25. What legal issues arise when testing servers in another country?

I must verify authorization, local cybersecurity laws, jurisdiction, data-protection requirements, and cross-border restrictions before beginning the test.

26. Can you test another system based only on the CEO's verbal permission?

I should obtain written authorization and update the signed scope before testing because verbal instructions may be insufficient to establish clear legal protection.

27. What should you do if you discover an active backdoor planted by an attacker?

I should avoid unnecessary changes, securely document evidence, notify the client immediately, preserve evidence integrity, and coordinate incident response and law-enforcement reporting where appropriate.

28. What should you do when a penetration-test contract is terminated?

I must immediately stop testing, cease using access credentials, safely terminate authorized sessions and shells as agreed, notify the client, preserve required evidence, and return or securely delete data according to the contract.

29. Who may be liable for exploiting a third-party cloud service outside the scope?

The tester may face liability for unauthorized access, while the client may also face contractual issues; precise scope definitions and third-party permissions help prevent such disputes.

30. Is hacking a foreign company at a government's request automatically legal?

No, national interest alone does not establish legal authority; the activity must be evaluated under applicable domestic laws, international law, jurisdictional rules, and relevant authorization requirements.

Ethical Hacking – Answers (31–40)

31. What protection does an authorization letter provide during a physical penetration test?

It provides evidence of permission within the defined scope, but it cannot guarantee immediate protection from police detention or override applicable laws.

32. Is probing publicly accessible systems legal despite their Terms of Service?

Not automatically; public accessibility does not equal authorization, and legality depends on applicable laws, the testing conduct, and relevant legal precedents or research protections.

33. What should you do if a medical-device vendor ignores a critical zero-day report for 90 days?

I should continue documented attempts to contact the vendor, coordinate with a relevant vulnerability-disclosure authority, assess patient safety, and disclose responsibly when justified rather than automatically publishing after 90 days.

34. Is publicly tweeting a banking-app vulnerability immediately ethical?

Generally, no, because immediate disclosure without notifying the bank can expose users to attacks; coordinated disclosure is usually safer.

35. How can researchers reduce legal risks in bug-bounty programs?

They should read program rules carefully, remain within scope, minimize data access, preserve evidence, and clarify authorization before conducting risky tests.

36. What if a vendor requests indefinite secrecy about a vulnerability?

I should seek a reasonable, documented disclosure timeline, consider user safety, coordinate with a trusted disclosure organization, and avoid indefinite secrecy that leaves users exposed.

37. How should a vulnerability in a widely used open-source library be disclosed?

I should notify maintainers privately, coordinate with relevant security organizations and downstream vendors, allow reasonable time for fixes, and publish actionable details when disclosure is safe.

38. Should you accept a hush payment to conceal a vulnerability permanently?

Not automatically; I should consider confidentiality obligations, user safety, applicable laws, and responsible disclosure principles before accepting any payment or restriction.

39. What if a vulnerability affects third-party software used by thousands of organizations?

I should notify the software vendor or maintainer through responsible disclosure, minimize further testing, and coordinate communication with affected parties to reduce widespread risk.

40. What should you do if another researcher publicly claims credit for your reported vulnerability?

I should maintain evidence of my original report, respect any agreed embargo, contact the researcher or vendor professionally, and resolve credit disputes through documented communication.